AI Agent Authentication and Authorization

draft-klrc-aiagent-auth-00

Pieter Kasselman
Defakto Security
Jeff Lombardo
AWS
Yaroslav Rosomakho*
Zscaler
Brian Campbell*
Ping Identity

IETF®

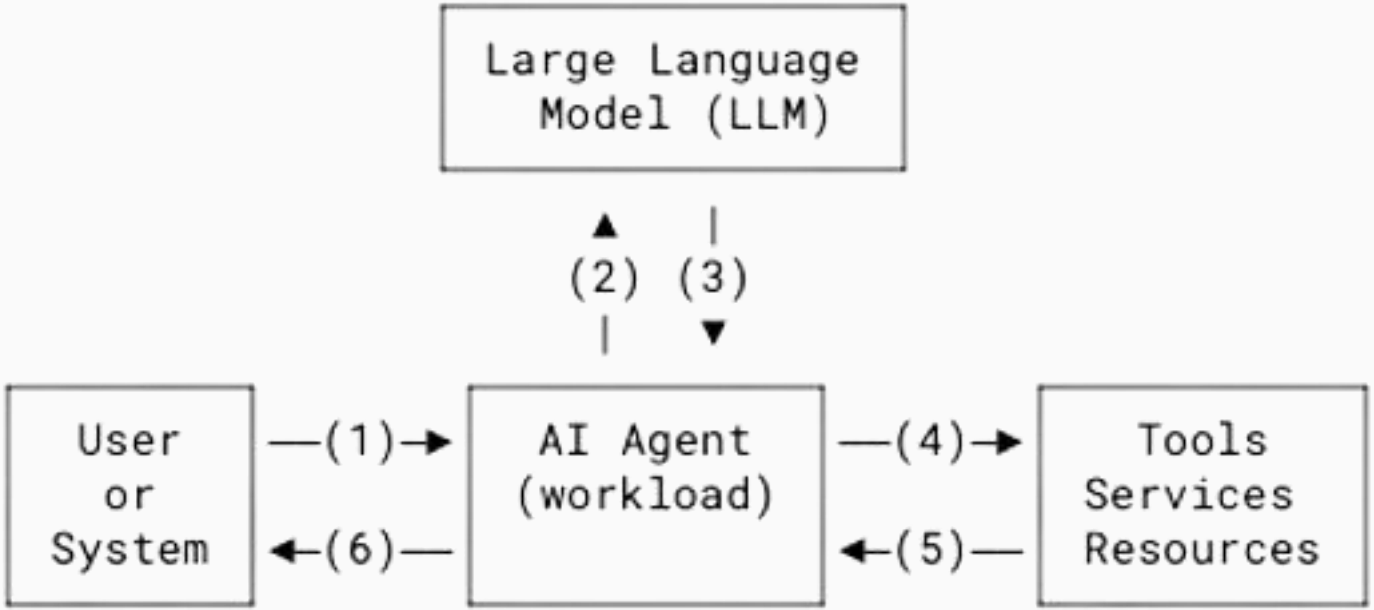
AI agents

IETF

AI agents require identity

IETF

Background: Agents are workloads



Motivation

AI is exploding. We need guardrails as soon as possible!

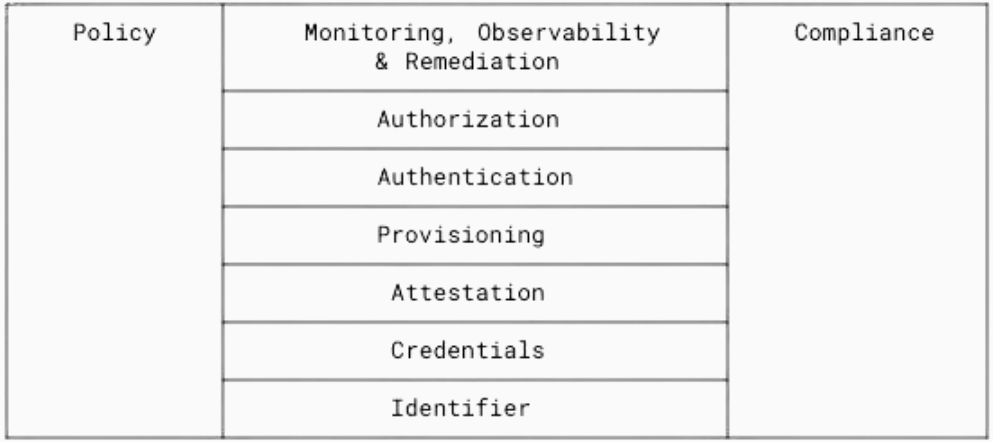
- There is a tendency to invent new “AI” protocols
- We MUST leverage the learnings and exiting standards of several decades of identity, authentication, and authorization
- There is a wide spectrum of standards involved, but there is no single framework guiding implementers to the right places

- We MAY locate missing pieces in existing standards to surgically address them

IETF

Background: What is this draft?

Informational draft to map existing (mainly IETF) technologies to Agentic communications auth



- Identifiers
- Credential Format
- Attestation
- Provisioning
- Authentication
- Authorization
- Monitoring and Observability

IETF

Agent identifier

- Every agent is assigned with unique identifier
- WIMSE ID is a generic form

- SPIFFE is a widely deployed WIMSE implementation
- Agent vendors may choose their own scheme and path notation

Agent credentials

- X.509 certificates or Workload Identity Tokens (WITs)
- SHOULD be protected by TPMs or Secure Enclaves
- Additional credentials may be obtained via Token Exchange
- Static API keys MUST NOT be used

Agent attestation

- Hardware-based attestation
- Software integrity evidence
- Supply-chain provenance
- Platform/orchestration layer attestation
- Often coupled with credentials provisioning

Agent provisioning

- Initial provisioning of credentials
- Rotation/renewal before expiration

Agent authentication

- Transport-layer or Application-layer
- mTLS is a great transport-layer option but cannot operate through intermediaries
- Application-layer is more flexible but is not cryptographically bound to the transport
- WIMSE Proof Tokens (WPTs) for non-HTTP
- HTTP Message Signatures for HTTP

Agent authorization

- Leverage Oauth 2.0 as the authorization framework
- Obtain access tokens through user delegation, own authorization or via other agents
- Leverage Transaction Tokens to reduce access token risks
- CIBA can be used for step-up authentication
- Privacy consideration are important: do not leak identifiers
- User Oauth 2.0 discovery capabilities

Q&A

IETF